

FULL NAME: ESTHER EGBAGBE

REGISTRATION NUMBER: C11/26/CGRCE/17574

COHORT: Cohort11

COURSE: GRC102 PRATICAL LAB

DATE SUBMITTED: 11th of Sept. 2026

Task 1: Governance Gap Assessment, Organizational Chart, RACI Matrix and Governance Rationale

Required Evidence Task 1

Current-State Governance Gap Assessment

1. Leadership and Oversight

Security activities are mainly handled by the IT team, and there is no clear Board-level oversight of security. This means important security issues may not get enough attention or direction from senior management, which is especially concerning after the recent data-leakage near-miss.

2. Roles and Responsibilities

John Smith, the IT Manager, handles infrastructure work along with some security tasks, but there is no clearly defined person responsible for security. This makes it difficult to know who is accountable when a security issue happens because security is only part of the IT Manager's job.

3. Risk Management

GHC's recent data-leakage near-miss shows that security issues may be handled reactively instead of through a proper risk management process. Without a formal risk assessment process, important risks may not be identified early and could become serious security incidents.

4. Policy Framework

GHC has grown through two acquisitions, so there may be different security policies and practices across the organization. Without one clear policy framework, different teams may follow different or even conflicting security requirements.

5. Business Alignment (Strategic Alignment)

GHC's security responsibilities are not clearly connected to its main business goals, such as expanding into new markets, maintaining customer trust, and meeting regulatory requirements. Without this

connection, security spending may focus too much on technical issues instead of what is most important to the business.

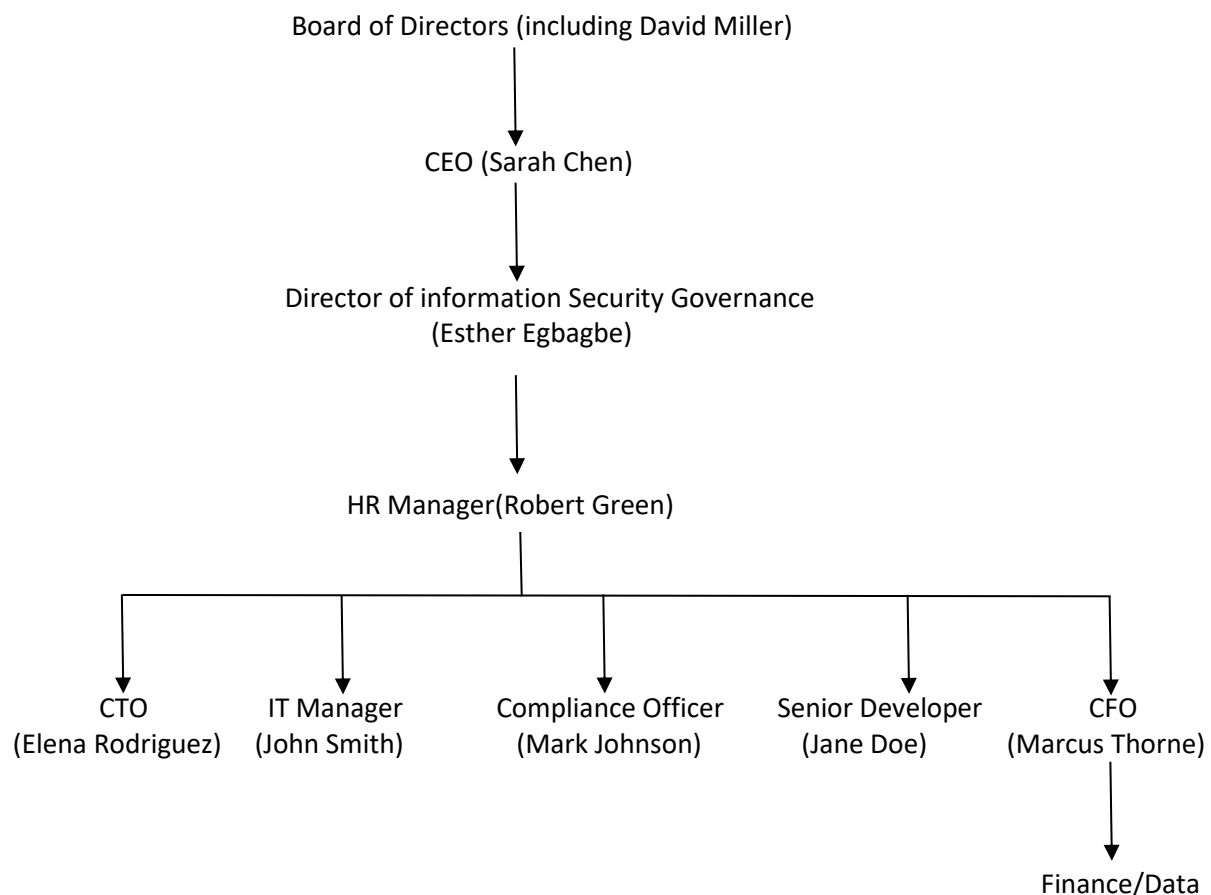
6. Performance Measurement

GHC does not have a clear and formal way of reporting security information or regularly providing security metrics to the Board. Without this, leadership may not have a clear picture of GHC's actual security situation, making it harder to make informed decisions based on reliable data.

7. Assurance Activities

GHC does not have a clearly defined independent assurance function, such as an internal audit role. This means there is no independent team checking whether the security controls are actually working as expected. Instead, management may have to rely mainly on information reported by the teams responsible for those controls.

Proposed Security Governance Organization Chart



RACI Matrix (covering at least 6 Governance Activities)

R- Respond A – Accountable C – Consulted I - Informed

Activity	Board	CEO	Dir. Info. Sec Gov.	CTO	IT Manager	Compliance	CFO
Security Policy Approval	I	A	R	C	C	C	I
Risk Assessment & Review	I	A	R	C	C	C	C
Incident Response Planning	I	A	R	C	R	C	I
Security Budget Approval	I	A	C	I	I	I	R
Third-Party/ Vendor Risk Review	I	I	A	C	C	R	C
Access Management(Onboarding/Off boarding)	I	I	A	I	R	C	I

4. A Short explanation of how the proposed structure supports accountability, transparency, business alignment and risk management

This structure improves accountability by giving the Director of Information Security Governance clear responsibility for governance decisions. The RACI matrix also makes it clear who is responsible for each activity, so there is no confusion.

It improves transparency because the Director reports directly to the CEO and Board, keeping security issues visible at the top. It also supports business alignment by involving the CFO, CTO, and Compliance Officer in relevant decisions. Finally, risk management and incident response become formal processes with clear owners instead of being handled in an informal or reactive way.

Task 2 – Information Security Charter

I. Purpose

This Charter establishes the mandate, authority, and structure for GHC's Information Security Programme. It exists to protect patient data and organizational systems while directly supporting GHC's five strategic goals for 2026: enabling safe Expansion of Market Share into new regional markets without introducing unmanaged risk; supporting Operational Efficiency by preventing costly security incidents and downtime that would undermine uptime targets; Maintaining Customer Trust by protecting patient information and working toward zero major data breaches; enabling Innovation, including AI-driven diagnostics and secure data-exchange capabilities, to be pursued safely; and directly supporting GHC's goal to Achieve Regulatory Excellence by proactively meeting healthcare and data-protection obligations.

II. Scope

This Charter applies to all GHC systems, applications, and data, including cloud-based patient management platforms, all employees and contractors, and third parties or vendors with access to GHC systems or data. It covers all locations and business units resulting from GHC's recent acquisitions, and extends to the new regional markets GHC plans to enter as part of its market expansion goal.

III. Authority

The Director of Information Security Governance is granted authority by the CEO and Board to set security policy, direct risk assessments, and require compliance with security standards across all departments. Escalation of unresolved security risks or major incidents may be made directly to the CEO or Board without requiring departmental approval.

IV. Roles and Responsibilities

High-level accountabilities are defined in the governance structure and RACI matrix established under Task 1, with the Director of Information Security Governance accountable for overall programme execution, the CEO accountable for executive sponsorship, and the Board accountable for governance oversight.

V. Key Principles

GHC's Information Security Programme is guided by four principles, each directly tied to GHC's strategic goals. Security decisions will be risk-based, prioritizing the greatest threats to patient data and business operations, supporting the goal of Maintaining Customer Trust. Security will be business-aligned, actively enabling Expansion of Market Share and Innovation rather than obstructing them. Controls will be proportionate to GHC's size and risk exposure, supporting Operational Efficiency by avoiding unnecessary complexity or cost. The programme will pursue continuous improvement, adapting as GHC grows and enters new markets, in support of Achieving Regulatory Excellence on an ongoing basis.

VI. Reporting Structure

The Director of Information Security Governance will report security posture to the CEO monthly and to the Board quarterly, with immediate escalation for major incidents. A Security Steering Committee will provide ongoing cross-functional oversight between formal Boards reporting cycles, ensuring risks affecting GHC's strategic goals are surfaced early.

VII. Review and Approval

This Charter is approved by the CEO and Board and will be formally reviewed annually or sooner if significant organisational changes such as further acquisitions or entry into new regional markets occur. Amendments require CEO and Board approval.

6. Justification Memo to Marcus Thorne, CFO, explaining how the Charter supports GHC's strategic goals, accountability and investment decisions.

This Charter formalises GHC's Information Security Programme, directly supporting our strategic goals for 2026. It protects patient data in support of Maintaining Customer Trust, establishes clear accountability ahead of our push to Achieve Regulatory Excellence, and ensures security is built into our plans to Expand Market Share and pursues Innovation, such as AI-driven diagnostics, without introducing unmanaged risk. From an investment perspective, the Charter ensures security spending is directed by risk-based priorities rather than ad-hoc reactive spending, and the defined reporting structure gives the Board and executive team ongoing visibility into risk exposure, supporting more informed budget and investment decisions as GHC continues to grow.

Task 3 – Board Reporting and Security Metrics

Board Executive Summary

Overall Security Posture: AMBER

GHC's security situation is getting worse and needs the Board's attention. Although security awareness training has been improving, the organization is not patching systems as well as before. At the same time, the number of vulnerabilities and attacks has increased. This has also caused high-risk security incidents to increase more than three times in six months.

GHC is not at a Red-level crisis yet, but the situation is becoming difficult to maintain. If the threats continue to increase while our ability to protect the organization decreases, action needs to be taken before the situation becomes more serious.

Five Selected Metrics

a) High-Risk Incidents

Status: 7 (February) | Trend: Rising — 2 → 7 over six months

Commentary: This is the clearest indicator that GHC's overall risk exposure is increasing. A more than threefold rise over six months signals that current defenses are not keeping pace with the threat environment.

b) Critical Vulnerability Patching

Status: 22 of 40 critical vulnerabilities patched (55%) in February | Trend: Declining on both measures — the percentage patched fell from 67% to 55%, while the total number of critical vulnerabilities identified each month rose from 15 to 40

Commentary: GHC isn't just patching a smaller share of vulnerabilities — it's facing a substantially larger and growing workload at the same time. Rising volume combined with falling completion compounds GHC's exposure window month over month.

c) Phishing Attempts

Status: 320 (February) | Trend: Rising — 150 → 320

Commentary: More than doubling over six months, this reflects a growing external threat targeting GHC directly, increasing pressure on staff vigilance and technical controls.

d) Malware Detections

Status: 50 (February) | Trend: Rising — 25 → 50

Commentary: Consistent doubling alongside phishing suggests a broader increase in attack volume against GHC, not an isolated issue.

e) Security Awareness Training Completion

Status: 70% (February) | Trend: Improving — 45% → 70%

Commentary: The one clearly positive trend — rising engagement suggests growing staff awareness, though at 70% completion, meaningful gaps remain.

Priority Risks and Recommendations

Risk 1: Rising critical vulnerability volume combined with declining patch completion

Recommendation: Allocate additional resources to the patching function immediately, and set a Board-visible target (e.g., 90%+ critical patch rate within 90 days) to reverse the current decline, given the growing volume of vulnerabilities being identified each month.

Risk 2: Rising high-risk incidents despite improving training

Recommendation: Commission a focused review of why incidents continue climbing despite training gains — likely indicating the gap lies in technical controls (e.g., patching, detection) rather than user awareness, and resources should be reallocated accordingly.

Rationale for Metric Selection

These five metrics were selected because they give the Board a complete, decision-useful picture without technical jargon: three measure the growing external threat (phishing, malware, incidents), one measures GHC's core defensive capability and its growing workload (critical vulnerability patching), and one measures organizational readiness (training). Together, they show not just that risk is rising, but specifically why attack volume and vulnerability discovery both increasing while patch completion weakens giving the Board a clear basis for resourcing decisions.

Task 4 – Security Steering Committee

Purpose

The Security Steering Committee (SSC) will provide cross-functional oversight of GHC's information security programme. It will bring different departments together to make important security decisions, resolve disagreements between departments, and make sure security decisions support GHC's business goals and risk appetite.

Scope

The SSC will be responsible for reviewing security policies, security risks, major security initiatives, and conflicts between departments. It will also help prioritize which security risks need to be addressed first. However, the SSC will not handle the day-to-day technical work. That responsibility will remain with the IT Manager and the relevant technical teams.

Membership

- Director of Information Security Governance (Chair)
- Chief Technology Officer (Elena Rodriguez)
- IT Manager (John Smith)
- Compliance Officer (Mark Johnson)
- CFO representative or delegate (Marcus Thorne)
- HR representative (Robert Green), for matters involving people/access

Responsibilities

The SSC will review and approve security policies before they are sent for final executive approval. It will also help resolve disagreements between departments on security matters and decide which security risks and initiatives should be given priority. For major security decisions, the SSC will provide recommendations to the CEO and Board.

Meeting Cadence

The SSC will meet once every month to review security issues, risks, and ongoing initiatives. Additional meetings can be held when there is an urgent disagreement between departments or a major security incident that needs quick attention.

Decision Authority

The SSC has the authority to approve operational security policies (such as the password policy). Decisions with significant budget or strategic impact will be recommended by the SSC for final approval by the CEO or Board.

Reporting

The SSC Chair (Director of Information Security Governance) will report SSC decisions and outstanding issues to the CEO monthly, feeding into the broader Board reporting structure established under Task 2.

Sample Agenda — First SSC Meeting

1. Welcome and introduction of SSC purpose and Terms of Reference
2. Review of current security posture (summary from Task 3 Board metrics)
3. Key discussion item: Password policy conflict CTO's balanced approach (MFA + secure password management) vs. IT Manager's stricter proposal (16-character complex passwords, 30-day rotation, no password-manager integration)
4. Discussion of relevant risk data and industry good practice to inform the decision
5. SSC decision on the password policy: After reviewing both proposals, the SSC recommends adopting the CTO's approach multi-factor authentication combined with secure password management over the IT Manager's proposal of 16-character passwords rotated every 30 days

without password-manager support. This aligns with current industry guidance, which favors MFA and secure password management over frequent forced password changes, as overly complex, frequently-rotated passwords without supporting tools tend to push users toward weaker workarounds such as writing passwords down or reusing predictable variations.

6. Review of other pending security initiatives
7. Confirm next meeting date and follow-up actions

CEO Briefing Note

The Security Steering Committee (SSC) was created to handle security disagreements, such as the current password policy conflict between the CTO and IT Manager, in a clear and structured way instead of dealing with them informally. In its first meeting, the SSC recommended the CTO's proposed approach of multi-factor authentication and secure password management, in line with current industry best practice (National Institute of Standards and Technology, 2020), rather than the IT Manager's stricter password rotation policy.

By bringing together Technology, Compliance, Finance, and HR, the SSC can look at both the security risks and the impact on the business. This can reduce disagreements between departments and make sure security decisions still support GHC's overall goals.

Task 5 – Governance Maturity Assessment

Maturity Assessment (1-5 Scale)

Governance Domain	Current-State Evidence	Maturity Level
Policy and Documentation	Policies inconsistent, inherited from acquisitions, not always current	2 – Initial
Roles and Responsibilities	Security ownership and accountability are unclear	1 – Ad Hoc
Risk Management	Lack of proactive assessment process	1 – Ad Hoc
Metrics and Reporting	Technical metrics exist but aren't consistently translated into business impact	2 – Initial
Training and Awareness	Annual training mandatory, but engagement is low	2 – Initial
Compliance	Preparation is audit-driven rather than continuously monitored	2 – Initial

12–18 Month Maturity Roadmap

Initiative 1: Formalize Governance Roles and Ownership

- Objective: Establish clear, named accountability for security governance (raises Roles & Responsibilities to Level 3)

- Key activities: Appoint the Director of Information Security Governance (per Task 1), implement the RACI matrix organization-wide, communicate roles to all departments
- Expected outcome: 100% of core governance activities have a named accountable owner within 6 months

Initiative 2: Standardize and Consolidate Security Policy

- Objective: Replace inconsistent, inherited policies with one unified, current policy set (raises Policy & Documentation to Level 3)
- Key activities: Audit existing inherited policies, close gaps against the new Information Security Charter (Task 2), publish a standardised policy suite with a defined review cycle
- Expected outcome: Unified policy suite approved and published within 9 months, with annual review built in

Initiative 3: Implement Formal, Recurring Risk Assessment

- Objective: Shift from reactive to proactive risk management (raises Risk Management to Level 3)
- Key activities: Establish a quarterly risk assessment cycle, maintain a live risk register reviewed by the Security Steering Committee (Task 4), feed key risks into Board reporting
- Expected outcome: Quarterly risk assessments and an active risk register in place within 6–9 months

Initiative 4: Embed Business-Focused Metrics Reporting

- Objective: Consistently translate technical metrics into business-relevant reporting (raises Metrics & Reporting to Level 3)
- Key activities: Adopt the five-metric Board reporting framework established in Task 3, automate data collection where possible, train report owners on business-focused interpretation
- Expected outcome: Monthly business-focused security reporting fully operational within 6 months

Initiative 5: Move Compliance from Audit-Driven to Continuous

- Objective: Embed ongoing compliance monitoring rather than periodic audit scrambles (raises Compliance to Level 3)
- Key activities: Implement a continuous compliance monitoring checklist/tool, conduct quarterly internal compliance reviews ahead of formal audits
- Expected outcome: Continuous compliance monitoring embedded within 12 months, reducing pre-audit preparation burden

Executive Summary to the board

GHC's current maturity and the strategic importance of the roadmap.

GHC's information security governance is currently at Level 1–2 (Ad Hoc to Initial) across all six areas assessed. This shows that the organization has grown quickly through acquisitions, but its governance structure has not developed at the same pace.

None of the areas currently reach Level 3 (Defined). This means that security processes are not yet consistently documented, responsibilities are not always clear, and security is mostly managed reactively instead of proactively.

The proposed 12–18 month roadmap is designed to address these gaps through five main priorities:

- Formalizing governance roles and responsibilities
- Standardizing security policies
- Introducing proactive risk assessments
- Improving Board-level security reporting
- Moving from reactive compliance to continuous compliance

The goal is to bring GHC to at least Level 3 across all six areas. With GHC planning to continue growing and facing increasing healthcare regulatory requirements, improving its security governance is important for protecting patient trust and supporting the organization's long-term goals.

Reference List

1. ICDFA GRC102: Information security governance [Course materials].
2. National Institute of Standards and Technology. (2020). Digital identity guidelines: Authentication and lifecycle management (NIST Special Publication 800-63B). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-63b>